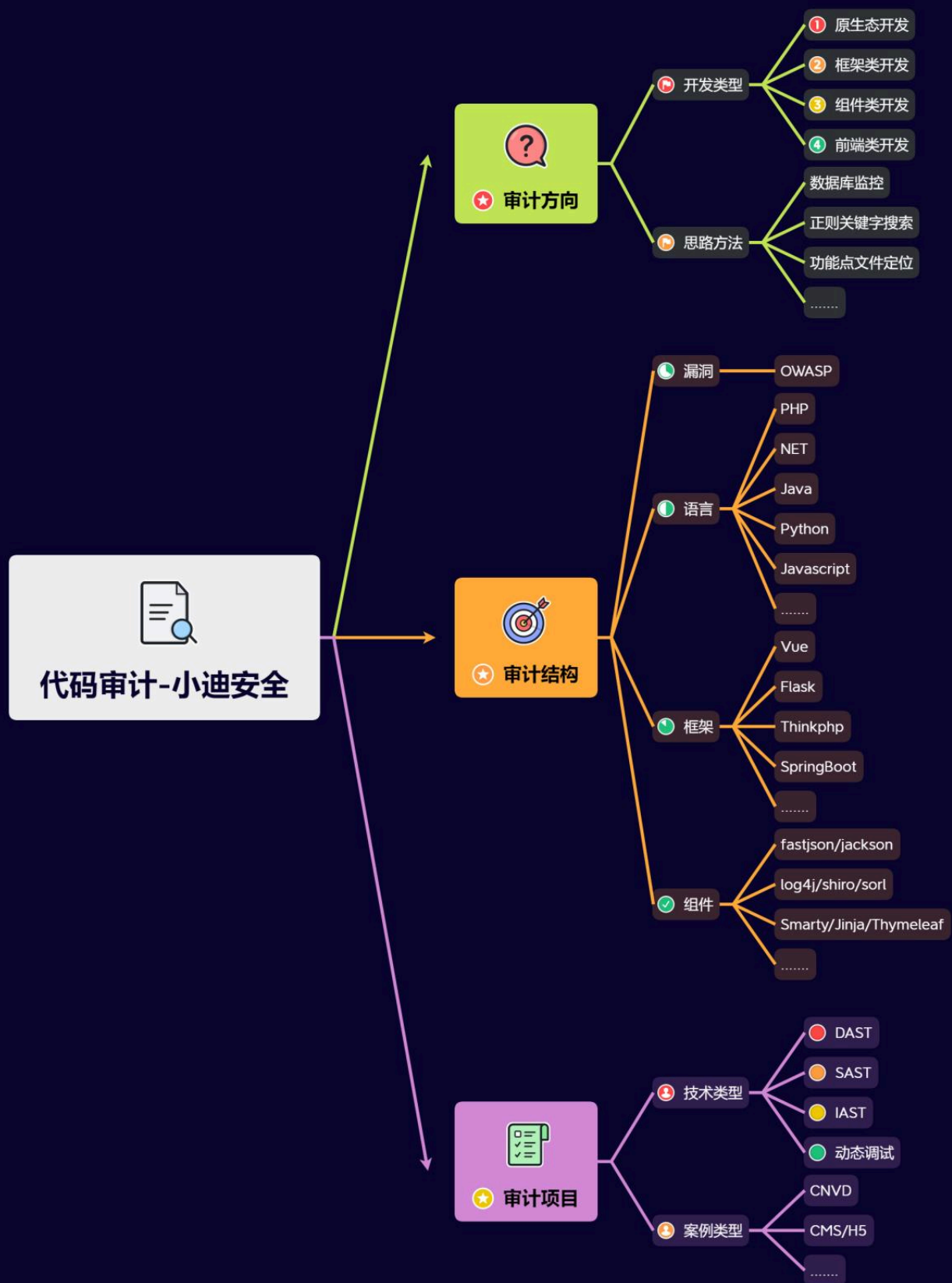


# Day130 代码审计-IAST&SAST项目篇&CodeQL 拓展&火线洞态&Agent部署&DevSecOps



## 1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

- 
- 1、PHP审计-原生态开发-SQL注入&语句监控
  - 2、PHP审计-原生态开发-SQL注入&正则搜索
  - 3、PHP审计-原生态开发-SQL注入&功能追踪

- 
- 1、PHP审计-MVC开发-RCE&代码执行
  - 2、PHP审计-MVC开发-RCE&命令执行
  - 3、PHP审计-MVC开发-RCE&文件对比

- 
- 1、PHP审计-动态调试-未授权安全
  - 2、PHP审计-文件对比-未授权安全
  - 3、PHP审计-未授权访问-三种形态

- 
- 1、PHP审计-动态调试-变量覆盖
  - 2、PHP审计-动态调试-原生反序列化
  - 3、PHP审计-动态调试-框架反序列化

- 
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
  - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞

- 
- 1、PHP框架审计-ThinkPHP-反序列化链分析
  - 2、PHP框架审计-ThinkPHP-反序列化链挖掘

- 
- 1、PHP框架审计-Yii-反序列化链分析
  - 2、PHP框架审计-Yii-实际CMS挖掘分析

- 
- PHP代审项目-TP框架-实战某违法微盘

- 
- 1、ASP.NET审计-SQL注入-继承架构&DLL反编译
  - 2、ASP.NET审计-SQL注入-数据库监控&关键字搜索

- 
- 1、ASP.NET审计-文件上传-DLL反编译&关键字搜索
  - 2、ASP.NET审计-文件上传-预编译解析&关键字搜索
- 

- 1、ASP.NET审计-未授权访问-未引用脆弱鉴权
  - 2、ASP.NET审计-未授权访问-不严谨鉴权逻辑
  - 3、ASP.NET审计-动态调试-附加进程&断点调试
  - 4、ASP.NET审计-程序逆向-EXE逻辑&修改覆盖
- 

- 1、JavaEE审计-文件安全-上传&下载&读取&写入等
  - 2、JavaEE审计-文件安全-功能点追踪&关键字搜索
- 

- 1、JavaEE审计-第三方组件-检测插件&利用条件
  - 2、JavaEE审计-第三方组件-FastJson&Log4j
  - 3、JavaEE审计-第三方组件-Shrio&H2database
- 

- 1、JavaEE审计-SSTI注入-FreeMarker&Thymeleaf
  - 2、JavaEE审计-补充Checklist-功能点&搜索关键
- 

- 1、JavaEE审计-FastJson-反序列化漏洞形成
  - 2、JavaEE审计-FastJson-低版本CC利用链分析
  - 3、JavaEE审计-FastJson-高版本CC利用链绕过
- 

- 1、JavaEE审计-原生开发-反序列化
  - 2、JavaEE审计-Shiro-550反序列化
  - 3、JavaEE审计-Shiro-URLDNS利用链
- 

- 1、JavaEE审计-Shiro-550反序列化
  - 2、JavaEE审计-Shiro-gadget&sink&source
  - 2、JavaEE审计-Shiro-CC2&CB1无依赖利用链
- 

- 1、JavaEE审计-CB链-TemplatesImpl&字节码加载
  - 2、JavaEE审计-CC链-Transform&TransformedMap&LazyMap
-

- 1、JavaEE审计-JNDI注入-LDAP&RMI服务
- 2、JavaEE审计-JNDI注入-LDAP&RMI高版本
- 3、JavaEE审计-JNDI注入-LDAP&RMI反序列化

-----

- 1、JavaEE审计-Tomcat-内存马分类&动态注册原理
- 2、JavaEE审计-Tomcat-Listen&Filter&Servlet

-----

- 1、SAST-IDEA插件SCA-依赖组件漏洞-JAVA
- 2、SAST-Fortify&CheckMarx&CodeQL-各语言
- 3、SAST-Bandit&NodeJsScan-Python&NodeJS

-----

- 1、SAST-CodeQL&CodeQLpy-JavaEE
- 2、IAST-洞态&部署&Agent加载-各语言

---

2.详细点

| 对比项       | DAST                        | SAST                  | IAST                 |
|-----------|-----------------------------|-----------------------|----------------------|
| 测试对象      | Web应用程序                     | Web应用程序<br>APP的漏洞     | Web应用程序<br>APP的漏洞    |
| 部署成本      | 低                           | 低                     | 高                    |
| 使用成本      | 较低, 基本无需人工验证                | 高, 人工排除误报             | 低, 基本没有误报            |
| 漏洞检出率     | 中                           | 高                     | 较高                   |
| 脏数据       | 非常多                         | 较少                    | 几乎没有                 |
| 研发流程集成    | 测试/线上运营阶段                   | 研发阶段                  | 测试阶段                 |
| 误报率       | 低                           | 高                     | 极低 (几乎为0)            |
| 测试覆盖度     | 低                           | 高                     | 高                    |
| 检查速度      | 随测试用例数量稳定增加                 | 随代码量呈指数增长             | 实时检测                 |
| 逻辑漏洞检测    | 支持部分                        | 不支持                   | 支持部分                 |
| 影响漏洞检出率因素 | 与测试payload覆盖度相关<br>企业可优化和扩展 | 与检测策略相关<br>企业可在定制策略   | 与检测策略相关<br>企业可定制测量   |
| 第三方组件漏洞检测 | 支持                          | 不支持                   | 支持                   |
| 支持语言      | 不区分语言                       | 区分语言                  | 区分语言                 |
| 支持框架      | 不区分框架                       | 区分框架                  | 区分框架                 |
| 侵入性       | 较高, 脏数据                     | 低                     | 低                    |
| 风险程度      | 较高, 扫挂/脏数据                  | 低                     | 低                    |
| 漏洞详情      | 中, 请求                       | 较高, 数据流+代码行数          | 高, 请求+数据流+代码行数       |
| CI/CD集成   | 不支持                         | 支持                    | 支持                   |
| 持续安全测试    | 不支持                         | 支持                    | 支持                   |
| 工具集成      | 无                           | 开发环境集成<br>构建工具、问题跟踪工具 | 构建工具、自动化             |
| 其他        | 无法定位漏洞的具体代码行数和产生漏洞的原因       |                       | 不支持C, C ++和Golang等语言 |

| 对比项   | DAST                              | SAST                               | IAST                                                                                  |
|-------|-----------------------------------|------------------------------------|---------------------------------------------------------------------------------------|
| 商业产品  | AppScan、AWVS、webinspect burpsuite | Fortify、 <a href="#">Checkmarx</a> | 默安-雳鉴IAST<br>新思Seeker软件<br>开源网安SecZone VulHunter<br>、墨云VackBot等，国外：Contrast Security等 |
| 开源产品  | Owasp ZAP、Xray                    | Raptor、RIPS、Seay源代码审计系统、VCG等       | 百度RASP等                                                                               |
| 部署成本  | 低                                 | 低                                  | 高                                                                                     |
| 使用成本  | 较低, 基本无需人工验证                      | 高, 人工排除误报                          | 低, 基本没有误报                                                                             |
| 漏洞检出率 | 中                                 | 高                                  | 较高                                                                                    |

| AST     | SAST   | DAST          | IAST   |
|---------|--------|---------------|--------|
| 误报率     | 高      | 低             | 低      |
| 检出率     | 高      | 中             | 高      |
| 第三方组件漏洞 | 静态扫描   | 依赖PoC、指纹      | 动态时支持  |
| 使用风险    | 无      | 产生脏数据         | 无      |
| 漏洞详情    | 一般     | 一般            | 详细     |
| 检出速率    | 根据代码量  | 根据PoC、URL     | 根据流量大小 |
| 漏洞种类    | 偏向代码漏洞 | 可发现运维、配置、运行漏洞 | 偏向应用本身 |

| 产品功能               | 功能描述                                                 | 开源版 | 商业版 |
|--------------------|------------------------------------------------------|-----|-----|
| Web应用漏洞检测          | 支持Owasp Top 10、CWE/SANS Top 25、PCI DSS 等类型的漏洞检测      | ✓   | ✓   |
| 多语言检测支持            | 支持Java、Python、PHP、Golang等语言的Web应用漏洞检测                | ✓   | ✓   |
| 漏洞详情与修复建议          | 支持详细的漏洞HTTP数据流及代调用数据流，漏洞提供漏洞修复建议及代码示例                | ✓   | ✓   |
| 漏洞有效性验证            | 支持全局漏洞主动验证及漏洞验证功能，确保漏洞有效性和修复后漏洞验证                    | ✓   | ✓   |
| 公开组件漏洞库            | 原始英文字段的NVD公开漏洞库数据                                    | ✓   | ✓   |
| 运行时组件识别及安全版本推荐     | 运行时依赖组件识别，确保真实调用版本                                   | ✓   | ✓   |
|                    | 支持依赖组件开源许可证商用合规分析                                    | ✗   | ✓   |
|                    | 漏洞利用性文章或其他研究文章                                       | ✗   | ✓   |
| 黑盒对接能力             | 组件安全版本，中文标题及描述                                       | ✗   | ✓   |
|                    | 支持对接黑盒，进行交叉验证工作                                      | ✗   | ✓   |
| 漏洞运营               | 自定义用户代码识别黑名单                                         | ✗   | ✓   |
|                    | 项目列表待确认漏洞过滤                                          | ✗   | ✓   |
| 性能配置               | agent数据采集黑名单                                         | ✗   | ✓   |
|                    | cpu、内存                                               | ✗   | ✓   |
|                    | 调用链长度配置                                              | ✗   | ✓   |
| 全局漏洞数据罗盘           | 基于漏洞来源、类型、状态等全局数据罗盘                                  | ✗   | ✓   |
| api采集              | 对客户应用内api信息进行采集，并提供测试覆盖率                             | ✗   | ✓   |
| 调用链查询              | 全量的请求调用链搜索，请求方法调用链路途                                 | ✗   | ✓   |
| 全链路漏洞检测            | 支持http api、Spring Cloud、Dubbo等微服务框架，全链路污点传播过程追踪及漏洞检测 | ✗   | ✓   |
| 漏洞报告导出             | 支持单个漏洞或单个组件分享                                        | ✗   | ✓   |
|                    | 支持PDF、WORD、XLS等格式的报告导出功能                             | ✗   | ✓   |
| 多账号管理              | 支持多角色、多账号及自定义权限的账号管理功能                               | ✗   | ✓   |
| 项目管理               | agent状态监控、预警                                         | ✗   | ✓   |
| 品牌漏出               | 品牌配置                                                 | ✗   | ✓   |
| 合规要求               | 审计日志                                                 | ✗   | ✓   |
| 系统集成               | CI/CD自动化测试和构建工具集成                                    | ✗   | ✓   |
|                    | 漏洞管理平台                                               | ✗   | ✓   |
|                    | 消息推送服务集成                                             | ✗   | ✓   |
| 远程支持服务             | 提供原厂的技术响应和支持服务                                       | ✗   | ✓   |
| 部署及培训服务（1次）        | 提供1次线下的产品部署及使用培训服务                                   | ✗   | ✓   |
| 自研框架适配服务（2个）       | 支持标准产品外的自研框架、二开框架的适配性服务                              | ✗   | ✓   |
| Agent运营支持服务、规则调优服务 | 提供原厂的Agent运营支持，确保iast产品部署后的价值产出                      | ✗   | ✓   |
| 检测能力               | 新漏洞商业版会提前更新，开源版漏洞检测能力滞后6个月                           | 滞后  | ✓   |

### 3.演示案例

#### 3.1 SAST-CodeQL&CodeQLpy-JAVA

- 1 #SAST-CodeQL&CodeQLpy-JAVA
- 2 测评：若依系统&Tmall商城
- 3 在官方规则引擎下升级Java检测
- 4 <https://github.com/webraybt1/codeqlpy>
- 5 1、安装Python依赖
- 6 2、安装JDK8&11,Maven
- 7 3、修改配置文件路径指向

#### 3.2 IAST-火线洞态-Agent&IDEA-JAVA

- 1 参考：<https://doc.dongtai.io/docs/introduction>
- 2 测评：若依系统&Tmall商城
- 3 1、环境搭建：
- 4 Ubuntu 18.04



```
5 apt update
6 apt install docker.io
7 cp docker-compose /usr/bin/docker-compose
8 chmod +x /usr/bin/docker-compose
9 修改配置文件，填入SCA-Token后直接拉取
10 cd DongTai/deploy/docker-compose/
11 ./dtctl install -v 1.9.1
12 2、Agent部署：
13 -IDEA插件
14 https://github.com/HXSecurity/DongTai-Plugin-IDEA/releases
15 https://doc.dongtai.io/docs/getting-started/agent/plugin/java-agent-idea
16 -Agent部署
17 netstat -ano | findstr xxxx
18 https://doc.dongtai.io/docs/category/agent-%E5%AE%89%E8%A3%85%E6%8C%87%E5%8D%97
```

### 3.3 IAST-代码审计-实例挖掘CNVD证书